

UNIVERSIDAD TECNOLÓGICA NACIONAL
FACULTAD REGIONAL TUCUMÁN
Departamento de Sistemas de Información

AUDITORÍA EN SISTEMAS DE INFORMACIÓN
Plan 2023 | 4.º Año | Ciclo Lectivo 2026

TRABAJOS FINALES INTEGRADORES
Trabajo de Integración Grupal (TIG) 2026

Cátedra de Auditoría en Sistemas de Información | UTN-FRT | 2026

1. PRESENTACIÓN GENERAL DEL TRABAJO FINAL INTEGRADOR

El Trabajo de Integración Grupal (TIG) es la instancia evaluativa central de la asignatura Auditoría en Sistemas de Información. Representa la síntesis práctica de los contenidos desarrollados durante el cuatrimestre y constituye una experiencia de aprendizaje que simula el ejercicio profesional real de la auditoría de sistemas.

Cada grupo de siete (7/8) integrantes deberá desarrollar una auditoría completa sobre una organización ficticia de referencia, siguiendo los lineamientos de la propuesta asignada. El trabajo debe demostrar dominio de los marcos normativos, capacidad analítica y **trabajo colaborativo en equipo**.

1.1 Características Fundamentales del TIG

- Grupos de trabajo: 7/8 integrantes por grupo, con roles definidos: Líder de Auditoría (1), Auditor Senior (1), Auditores (4), Especialista Técnico (1).
- Organizaciones: Todas las organizaciones auditadas son ficticias y creadas por el grupo.
- El informe final tiene estructura bipartita: Resumen Ejecutivo (destinatario: Alta Dirección) + Informe Detallado (destinatario: Gerencia de TI/Área de Sistemas).
- Creatividad requerida: El grupo debe demostrar pensamiento propio. No es suficiente generar documentos con Inteligencia Artificial; se evaluará el razonamiento, la argumentación y la originalidad del análisis.

1.2 Uso de Inteligencia Artificial

Se permite el uso de herramientas de Inteligencia Artificial (IA) como apoyo secundario para redacción, búsqueda de información y mejora de textos. Sin embargo:

- El uso de IA sin análisis crítico propio será penalizado en el criterio de '**Originalidad y trabajo propio**'.
- Cualquier contenido generado íntegramente por IA, sin elaboración del grupo, será considerado como entrega incompleta.

Los siguientes elementos deben ser elaborados exclusivamente por el grupo:

- La organización ficticia completa: nombre, estructura, sistemas, personal, documentación interna.
- Los registros ficticios (usuarios, incidentes, tickets, logs, listas de visitantes) usados como evidencia. Los hallazgos, observaciones y recomendaciones deben surgir del análisis propio del grupo.
- Durante la defensa oral, cada integrante debe poder explicar y fundamentar cualquier parte del trabajo.
- El CEAC (Cuestionario de Evaluación del Ambiente de Control) y su calificación; el Plan y Programa de Auditoría; la Matriz de Riesgos.
- Los Papeles de Trabajo y la redacción de las observaciones con estructura NCCE.
- El razonamiento detrás de la selección de observaciones vs. controles adecuados.

El objetivo es que los estudiantes desarrollen **criterio profesional propio**. **La IA puede ser una herramienta, pero no el autor del trabajo.**

1.3 Entregas

El día 25 JUNIO se realizará la primera entrega. A partir del 2 de Julio se establecerá fecha de defensa oral para cada grupo.

2. RÚBRICA DE EVALUACIÓN DEL TIG

La evaluación del TIG se realizará aplicando los siguientes criterios y ponderaciones:

CRITERIO DE EVALUACIÓN	PESO	DESCRIPCIÓN
Propuesta de Auditoría (Fase 1)	10%	Compleitud y calidad de la propuesta: presentación de la firma auditora, comprensión del negocio, alcance, metodología, cronograma y presupuesto de honorarios ficticios. Carta de compromiso formal.
Planificación y Ambiente de Control (Fase 2)	15%	CEAC y Nivel de Confianza justificado. Plan de Auditoría. Matriz de riesgos.
Controles Generales TI y Normativa (Fase 3)	15%	Evaluación de las categorías de CGTI. Aplicación del estándar asignado con citas precisas. PT-NORM-01 completo. Coherencia entre controles evaluados y organización ficticia.

Papeles de Trabajo (PT) y Evidencia (Fase 4)	20%	Evidencia suficiente, pertinente y apropiada. PT-OBS-XX por cada observación elevada al informe.
Selección de Observaciones (Fase 5)	15%	Criterio profesional en la selección (5–8 observaciones). Estructura NCCCE completa. Coherencia entre PT y observaciones.
Informe Bipartito (Fase 6)	25%	Parte A (Resumen Ejecutivo, máx. 3 pág.) adecuado para Alta Dirección: lenguaje claro, cuadro de observaciones con nivel de riesgo y recomendaciones estratégicas. Parte B (Informe Detallado) técnico y riguroso para área de TI: CEAC, CGTI, observaciones NCCCE y plan de acción con responsables y plazos.
TOTAL	100%	Nota final (1–10) = suma ponderada. Mínimo para aprobar: 60%.

2.1 Escala de Calificación

La nota del TIG se calculará sobre 10 puntos. La aprobación requiere un mínimo de 6 (seis), equivalente al 60% del puntaje total según la escala institucional:

- Nota 6: 60%-68% — Aprobado
- Nota 7: 69%-77% — Bueno
- Nota 8: 78%-86% — Muy Bueno
- Nota 9: 87%-95% — Distinguido
- Nota 10: 96%-100% — Sobresaliente

3. METODOLOGÍA OBLIGATORIA — 6 FASES DEL PROCESO AUDITOR

Todos los TIG deben evidenciar el recorrido completo por las siguientes 6 fases. Son obligatorias y representan el proceso profesional de auditoría de SI.

FASE 1 — PROPUESTA DE AUDITORÍA AL CLIENTE

Objetivo

El grupo actúa como firma auditora externa. La propuesta justifica el servicio y establece las condiciones del compromiso profesional antes de iniciar cualquier trabajo.

Contenido obligatorio

- Presentación de la firma auditora: nombre, equipo (con roles), experiencia ficticia y código de ética.
- Comprensión del negocio del cliente: descripción de la organización, sector, procesos de TI y riesgos inherentes de la industria.
- Alcance propuesto: sistemas, procesos y período a auditar, con justificación basada en los riesgos identificados.
- Objetivos específicos de la auditoría
- Metodología: marcos de referencia, tipos de pruebas y enfoque (cumplimiento vs. sustantivo).
- Equipo asignado con roles y responsabilidades de los 7 integrantes.
- Cronograma estimado en semanas y presupuesto de honorarios (ficticio y justificado).
- Carta de compromiso firmada ficticiamente por ambas partes.

FASE 2 — PLANIFICACIÓN Y EVALUACIÓN DEL AMBIENTE DE CONTROL

Objetivo

Determinar el alcance definitivo, la estrategia y el nivel de profundidad de las pruebas. La evaluación del ambiente de control fija el Nivel de Confianza (NC) que el auditor puede depositar en los controles existentes.

Cuestionario de Evaluación del Ambiente de Control (CEAC)

El grupo elabora un CEAC.

<u>PUNTAJE CEAC</u>	<u>NIVEL DE CONFIANZA</u>	<u>ESTRATEGIA DE PRUEBAS</u>	<u>IMPLICANCIAS</u>
75%–100%	ALTO	Pruebas de cumplimiento extensas. Menor volumen de pruebas sustantivas.	El auditor puede apoyarse en los controles. Muestras menores en pruebas de detalle.
45%–74%	MEDIO	Combinación equilibrada de pruebas de cumplimiento y sustantivas.	Énfasis adicional en áreas con controles débiles identificados en el CEAC.
0%–44%	BAJO	Predominio de pruebas sustantivas. Las pruebas de cumplimiento son insuficientes.	No se puede apoyar en controles. Se amplía el alcance de pruebas de detalle.

Documentos del Plan de Auditoría

- **Plan de Auditoría (PA):** alcance definitivo, objetivos, criterios normativos, recursos, fechas y horas por fase.
- **Matriz de Riesgos:** mínimo 8 riesgos con probabilidad, impacto, nivel resultante y control asociado.
- Acta de inicio firmada ficticiamente.

FASE 3 — CONTROLES GENERALES DE TI (CGTI)

Objetivo

Evaluar los controles que afectan transversalmente a todos los sistemas de la organización. Los CGTI condicionan la confiabilidad del entorno TI auditado.

Los grupos deben:

1. Evaluar en profundidad cada OC asignado: al menos 3 pruebas específicas por OC, con PT correspondiente.
2. Citar explícitamente el artículo, sección o número de control del estándar asignado para cada hallazgo o conformidad.

Las Categorías de Controles Generales de TI a modo de ejemplos:

#	CATEGORÍA	ASPECTOS A EVALUAR
1	Seguridad Física	Acceso a instalaciones TI, data center, racks. Controles ambientales: temperatura, humedad, UPS, extinción de incendios.
2	Seguridad Lógica	Gestión de identidades y accesos, política de contraseñas, MFA, perfiles, privilegios y segregación de funciones.
3	Gestión de Cambios	Proceso formal de cambios en sistemas y configuraciones. Ambientes DEV/TEST/PROD. Control de versiones.
4	Backups y Recuperación	Política de backups, frecuencia, retención, almacenamiento fuera del sitio, pruebas de restauración. DRP. RTO/RPO.
5	Gestión de Incidentes	Proceso de detección, clasificación, respuesta, cierre y lecciones aprendidas. Escalamiento. Registro de incidentes.
6	Seguridad en Redes	Segmentación de red, firewalls, IDS/IPS, cifrado en tránsito, acceso remoto (VPN), monitoreo del tráfico.
7	Acuerdos de Confidencialidad	Acuerdos con empleados, proveedores y terceros. Política de Uso Aceptable de TI. Cumplimiento y monitoreo.
8	Monitoreo y Auditoría TI	Logs de actividad, revisión periódica, alertas de seguridad, KPIs/KGIs de TI, reportes a la Alta Dirección.

FASE 4 — PAPELES DE TRABAJO Y EVIDENCIA DE AUDITORÍA

Objetivo

Los PT son el registro permanente del trabajo realizado. Soportan las conclusiones del informe y permiten a un auditor externo reproducir el trabajo y llegar a las mismas conclusiones.

Los 12 campos obligatorios de cada Papel de Trabajo

CAMPO	DESCRIPCIÓN Y CONTENIDO ESPERADO
Referencia (Ref.)	Código único: PT-[ÁREA]-[NN]. Ejemplos: PT-SL-01 (Seguridad Lógica N°1), PT-OC3-01 (OC-3 N°1), PT-OBS-02 (Observación N°2).
Fecha	Fecha de elaboración del PT.
Elaborado por	Integrante(s) del grupo responsable(s).
Revisado por	Líder de Auditoría o Auditor Senior del grupo.
Área / OC auditado	Categoría de CGTI específico al que corresponde el PT.
Objetivo del PT	Qué se pretende verificar o demostrar con este PT específico.
Procedimiento aplicado	Tipo de prueba: entrevista ficticia, inspección, análisis de muestras, observación, re-ejecución, análisis analítico.
Evidencia obtenida	Descripción de la evidencia: documental, analítica, testimonial u observacional. Puede ser descripción textual de capturas simuladas o planillas ficticias.
Resultado	El control existe y funciona? Hay excepciones?
Conclusión del PT	ADECUADO (no genera observación) o DEFICIENTE (remite a PT-OBS-XX). Una o dos oraciones precisas.
Referencia normativa	Control, artículo o proceso del estándar asignado que se evalúa en este PT.

FASE 5 — SELECCIÓN DE OBSERVACIONES Y CONTROLES ADECUADOS

Objetivo

Desarrollar el juicio profesional del auditor: distinguir qué controles funcionan bien de qué deficiencias son significativas para el informe, y entre estas últimas, cuáles merecen ser formalmente comunicadas.

criterios para elevar una observación al informe

CRITERIO	DESCRIPCIÓN
1. Significatividad	El control faltante expone a un riesgo de alto o medio impacto? Deficiencias de bajo impacto y baja probabilidad no se elevan al informe formal.
2. Materialidad	La deficiencia afecta a una cantidad significativa de transacciones, usuarios o activos críticos?
3. Recurrencia	Es una deficiencia sistemática (múltiples casos en la muestra) o un evento puntual? La recurrencia aumenta la relevancia para el informe.
4. Potencial de mejora	La organización puede implementar correcciones concretas y mensurables? Las observaciones deben ir con recomendaciones implementables.

Estructura NCCCE de cada Observación

- N — NORMA / CRITERIO: qué establece el estándar aplicable (citar artículo o control específico).

- C — CONDICIÓN: situación actual encontrada en la organización ficticia.
- C — CONSECUENCIA/IMPACTO: riesgo real o potencial para la organización (cuantificar cuando sea posible).
- E — RECOMENDACIÓN: acción concreta, con responsable sugerido y plazo estimado.

Controles Adecuados — documentación obligatoria

Para cada control que resulte ADECUADO, el PT concluye: 'Control evaluado: ADECUADO — No genera observación'. Mínimo obligatorio: 3 a 5 controles adecuados documentados. Esta documentación demuestra que el auditor evaluó áreas donde no encontró deficiencias.

FASE 6 — INFORME BIPARTITO DE AUDITORÍA

Objetivo

El informe se emite en dos documentos diferenciados con destinatarios, lenguaje y nivel de detalle distintos. Esta práctica refleja la realidad profesional de la auditoría de SI.

PARTE A — Resumen Ejecutivo (destinatario: Alta Dirección / Directorio)

Extensión máxima: 3 páginas. Lenguaje ejecutivo. sin palabras técnica

- Carta de elevación del informe: párrafo formal con fecha, período auditado y firma del Líder de Auditoría.
- Propósito y alcance: síntesis en 2 párrafos (qué se auditó y con qué metodología).
- Conclusión general: calificación del ambiente de TI (Adecuado / Con Observaciones / Deficiente) con justificación breve.
- Cuadro resumen de observaciones: tabla con las 5–8 observaciones, nivel de riesgo (Alto/Medio/Bajo) y una línea ejecutiva de descripción.
- Top 3 de riesgos identificados: en lenguaje de negocio, sin tecnicismos.
- Recomendaciones estratégicas: 3–5 recomendaciones de alto nivel
- Próximos pasos: plan de seguimiento de las recomendaciones.

PARTE B — Informe Detallado (destinatario: Gerencia de TI / Área de Sistemas)

Sin límite de páginas. Lenguaje técnico preciso. El plan de acción debe tener responsables, plazos y prioridad.

- Carta de presentación técnica al Gerente de TI o Jefe del Área de Sistemas.
- Antecedentes y contexto: descripción completa del entorno tecnológico auditado.
- Alcance y limitaciones del trabajo de auditoría.
- Metodología: enfoque, marcos normativos, tipos de pruebas, criterios de muestreo.
- Resultado del CEAC: tabla por categoría con puntaje y Nivel de Confianza determinado.
- Evaluación de CGTI: tabla resumen de las categorías evaluadas.
- Desarrollo de observaciones: ficha NCCE completa para cada observación.
- Plan de Acción: tabla con observación, responsable sugerido, plazo y prioridad de implementación.

Anexos: papeles de trabajo seleccionados, matrices y diagramas.